

Rapport d'Audit de Sécurité Passif - Étude de Cas : Moulinex.fr

1. Résumé exécutif

Objet : L'objectif de cet exercice est de réaliser une étude de cas concret permettant de découvrir la cybersécurité et de se familiariser avec des outils d'audit de cybersécurité, tout en restant dans un cadre légal.

Pour cet audit, j'ai été accompagné des IA Gemini et ChatGPT, qui m'ont aidé dans ma démarche d'apprentissage, et m'ont aidé à rédiger ce rapport.

Les contrôles observables dans le cadre de cet audit passif ne permettent pas de mettre en évidence des vulnérabilités critiques. Différentes actions de correction pourraient néanmoins améliorer la sécurité du site.

2. Périmètre et limites de l'audit

Cible auditée : <https://moulinex.fr>

Méthodologie : Audit externe passif, non-intrusif (sans scan de vulnérabilités agressif).

Les observations présentées dans ce rapport correspondent à l'état observable du site de Moulinex le 5 septembre 2026.

Cet audit étant réalisé selon une méthodologie passive, il ne permet pas de conclure à l'absence de vulnérabilités.

3. Analyse technique et résultats

I. Analyse des en-têtes http

Pour analyser les en-têtes http du site de Moulinex, nous allons utiliser l'outil <https://securityheaders.com/>

a. Constat

Nous constatons premièrement que la note attribuée aux en-têtes http du site est de C (notes allant de A+ à F).

Les entêtes Strict-Transport-Security, X-Content-Type-Options et X-Frame-Options semblent bien configurées.

En revanche, les en-têtes Content-Security-Policy, Referrer-Policy et Permissions-Policy semblent absentes.

b. Risques

L'en-tête Content-Security-Policy étant mal configurée ou absente, le site ne dispose pas d'une politique de défense, supplémentaire à celle déjà présente, permettant de limiter les attaques XSS. Nous ne sommes pas en mesure, à ce stade, de déterminer si le site est sensible aux attaques XSS.

L'en-tête Referrer-Policy étant mal configurée ou absente, un attaquant peut obtenir des informations sur l'URL consultée avant d'arriver sur la page web

L'en-tête Permissions-Policy étant mal configurée ou absente, le périmètre des fonctionnalités sensibles du navigateur sur le site n'est pas défini.

Mais cela ne signifie pas pour autant que toutes ces fonctionnalités sont accessibles automatiquement au site.

c. Corrections

Configurer l'en-tête Content-Security-Policy comme suit pourrait être une solution :

Content-Security-Policy : script-src <liste_blanche_scripts_autorises> ; img-src 'self' ; media-src <liste_blanche_medias> ;

Ce pattern est à appliquer selon les usages du site internet afin de restreindre l'exposition aux risques d'attaques XSS.

La configuration de cet en-tête via la balise <meta> n'est pas forcément recommandée car toutes les directives ne sont pas prises en compte.

Configurer l'en-tête Referrer-Policy comme suit pourrait être une solution :

Referrer-Policy: strict-origin-when-cross-origin

<meta name="referrer" content=" strict-origin-when-cross-origin " />

Configurer l'en-tête Permissions-Policy comme suit pourrait être une solution si le site n'utilise ni la caméra, ni le microphone:

Permissions-Policy: camera=(), microphone=()

Il faudrait, pour bien faire, désactiver, selon ce modèle, tous les éléments inutilisés afin de réduire le champ d'attaques éventuelles.

II. Chiffrements (SSL/TLS)

Pour analyser le chiffrement du site de Moulinex, nous allons utiliser l'outil

<https://www.ssllabs.com/ssltest/>

a. Constat

Nous pouvons constater qu'il y a 4 adresses IP qui ressortent du test. 2 adresses IPv4 et 2 adresses IPv6.

Nous ne pouvons pas l'affirmer, mais il est possible qu'il s'agisse d'une redondance.

En essayant de me rendre directement sur ces adresses IP sur mon navigateur, je reçois l'erreur 1003 (direct IP access not allowed), qui est une erreur Cloudflare.

Les certificats sont donc fournis par Cloudflare.

Les notes de ces 4 adresses IP sont A+ (notes de A+ à F).

Les protocoles TLS 1.0, TLS 1.1, SSL 2 et SSL 3 sont bien désactivés (car obsolètes), et TLS 1.2 et 1.3 sont bien activés.

Le site de Moulinex semble bien chiffré et semble capable de limiter les attaques Man-In-The-Middle.

Concernant les suites cryptographiques, certaines sont faibles (obsolètes). Parmi celles-ci, certaines sont remplacées par leur algorithme moderne, d'autres ne le sont pas.

b. Risques

Malgré le fait que le chiffrement soit de bonne qualité, la présence d'algorithmes faibles peut être problématique.

Si un utilisateur utilise un vieux navigateur (et donc qui possédera uniquement de vieux algorithmes faibles), le serveur n'aura pas d'autre choix que de sélectionner un algorithme faible qu'ils auront en commun.

Au contraire, si le serveur ne possédait que des algorithmes forts, le vieux navigateur et lui n'auraient pas d'algorithme commun pour la procédure. La connexion au serveur ne se ferait donc pas. Cela est donc, factuellement, plus sécurisé.

Cela pourrait inciter l'utilisateur à mettre à jour son navigateur.

c. Corrections

Il n'y a pas beaucoup de correction à apporter. Le simple fait de retirer les vieux algorithmes de chiffrement du serveur améliorerait grandement le système de chiffrement. Le système étant déjà assez bien sécurisé.

III. Protection des emails

Pour analyser la sécurité des serveurs SMTP du site de Moulinex, nous allons utiliser l'outil <https://mxtoolbox.com>

a. Constat

Nous pouvons constater en analysant le site de Moulinex que tous les voyants sont au vert.

b. Risques

Aucun risque ne semble identifié par ce test.

c. Corrections

Pas de correction particulière à mettre en place

IV. Reconnaissance du site

a. Constat

Robtos.txt : Le fichier robots.txt ne semble pas contenir de chemins compromettants.

Les accès admins ne sont donc pas divulgués dans ce fichier.

Sitemap.xml : Le fichier ne semble pas lister d'URL compromettantes

Security.txt : Le fichier ne semble pas exister, ce qui peut rendre plus difficile le lien avec la marque en cas de détection de failles. En effet, aucun canal de communication officiel n'est proposé. Cela peut empêcher la marque d'être tenue informé par des chercheurs en sécurité par exemple.

Concernant les requêtes XHR, des appels API sont fait (amazon-ads, api.iadvize.com, des traqueurs, paypal etc...). Il ne semble pas y avoir d'appels d'API suspects.

Les google Dorks vont me permettre de détecter s'il est possible d'accéder à des informations sensibles.

- site:*.moulinex.fr -www : afin de repérer les sous domaines indexés par les moteurs de recherche et de vérifier qu'il n'existe pas de domaines de dev ou de staging, tout en excluant le site principal.

Nous y trouvons le domaine <https://jeu.moulinex.fr> faisant référence à un jeu concours de Moulinex récemment terminé.

La présence d'autres sous domaines augmente potentiellement la surface d'exposition. Le jeu concours étant terminé, nous pouvons nous demander s'il est pertinent de garder ce sous domaine actif.

- site:moulinex.fr inurl:api : afin de trouver des endpoints d'API publiquement indexés qui pourraient exposer des structures de données ou des documentations de développement.

Aucun résultat.

- site:moulinex.fr filetype:sql OR filetype:db OR filetype:bkp : afin de détecter d'anciennes sauvegardes de bases de données oubliées sur le serveur.

Aucun résultat.

- site:moulinex.fr filetype:log : afin de rechercher des fichiers de logs d'erreurs qui pourraient divulguer des chemins système, des versions de logiciel ou des requêtes clients.

Aucun résultat.

- site:moulinex.fr filetype:conf OR filetype:ini OR filetype:env : afin de chercher des fichiers de configuration qui pourraient contenir des secrets ou des variables d'environnement.
Aucun résultat.
- site:moulinex.fr filetype:pdf OR filetype:xlsx OR filetype:docx "interne" OR "confidentiel" OR "admin OR filetype:txt "interne" OR "confidentiel" OR "admin": afin de trouver des manuels, rapports, tableurs de stocks ou listes de contacts contenant des mots-clés sensibles.
Aucun résultat.
- site:moulinex.fr inurl:admin OR inurl:login OR inurl:wp-login OR inurl:administrateur : afin de vérifier si des URL ne permettent pas d'accéder aux accès administrateurs du site.
Aucun résultat.
- site:moulinex.fr intitle:"dashboard" OR intitle:"connexion" OR intitle:admin : afin de vérifier qu'il n'existe pas de page contenant un titre d'onglet permettant d'être utilisé de manière contournée. Car une page possédant un titre d'onglet « Admin » ne signifie pas obligatoirement que le contenu est une page d'administration (bien que cela soit une très mauvaise pratique du point de vue du SEO).
Aucun résultat.
- site:moulinex.fr "Fatal error:" OR "database error" OR "stack trace" : afin de trouver des erreurs qui pourraient révéler les technologies précises utilisées sur le site.
Aucun résultat.

Le domaine semble propre, aucunes traces de point d'entrées, ou de divulgation d'informations ne semble présentes.

b. Risques

L'absence de résultat ne permet pas de conclure à l'absence de fichiers ou de ressources sensibles. Les résultats ne se limite qu'aux requêtes effectuées ci-dessus et ne peut garantir qu'il n'y a pas de fichier ou informations exposées

c. Corrections

Pas de correction particulière à mettre en place

4. Conclusion

Le site <https://www.moulinex.fr/> semble être un site suffisamment fiable et sécurisé.

Nous ne pouvons cependant pas affirmer l'absence de faille ou d'informations publiquement accessibles.

Les entêtes http sont perfectibles, et le score de C place ce site dans la catégorie « peut mieux faire », mais les ajustements peuvent être effectués rapidement et facilement.

Du côté des certificats TLS, la configuration est plutôt bonne, et les certificats sont fournis par Cloudflare. Une amélioration pourrait être faite en retirant du serveur certains algorithmes de chiffrement obsolètes.

Les serveurs mails semblent bien configurés et bien rootés.

Le google Dorking permettant de trouver des éléments compromettants n'a fourni aucun résultat, ce qui est très bien. A noter que nous n'avons peut-être pas couvert toutes les requêtes de google Dorking possibles.

Thème	Action à mener
Entêtes HTTP	Mieux renseigner les entêtes Content-Security-Policy, Referrer-Policy et Permissions-Policy
Certificats TLS	Supprimer les algorithmes de chiffrement obsolètes
Mails et SMTP	Rien de particulier
Google Dorking	Rien de particulier